

Корелација догађаја, ефективност контрола и учење

Корелација догађаја, процена контрола и постинцидентна анализа

Корелација и ефективност контрола

Догађаји добијају значење кроз заједнички контекст, а контрола се процењује на основу актуелног и проверљивог доказа.

ПРЕДМЕТ АНАЛИЗЕ

Ризик који се анализира

Процена безбедности обухвата везу између догађаја, контрола и доказа. Корелација даје контекст догађајима, а актуелан доказ омогућава процену рада контроле и последица инцидента.

ЗНАЧАЈ

Значај за безбедност система

Мерење ефективности спречава лажни осећај сигурности. Контрола која постоји, али је погрешно подешена, никада тестирана или без власника, не заслужује исто поверење као контрола са проверљивим доказом.

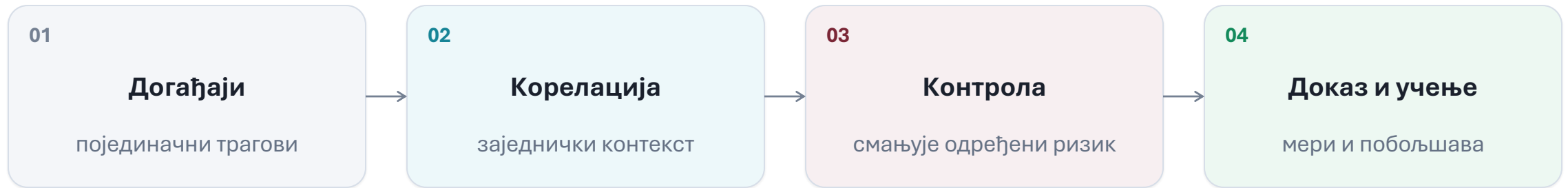
КРИТЕРИЈУМ ПРОВЕРЕ

Проверљив резултат

Одлука је јасна, примењује се на серверу и оставља поновљив доказ успешног и одбијеног исхода.

ОСНОВНИ ПОЈМОВИ

Догађаји, корелација, контрола и доказ омогућавају процену стварног безбедносног исхода.



ЗАКЉУЧАК

Безбедност напредује кроз повратну спрегу: доказ мења разумевање ризика, а то мења контролу.

Догађаји

појединачни трагови

01

Догађај бележи време, актера, ресурс, тип и идентификатор тока.

Питање: који улаз покреће ову одлуку?

02

Један догађај ретко је довољан за закључак; значење долази из везе са другима.

Питање: која граница мора бити видљива?

03

Догађаји без идентификатора тока не могу се поуздано повезати.

Питање: који доказ остаје после исхода?

ПИТАЊЕ ЗА АНАЛИЗУ

Који подаци морају постојати у сваком догађају да би се касније могао повезати са другима?

Корелација

заједнички контекст

01

Корелација групише догађаје истог тока у један случај.

Питање: који улаз покреће ову одлуку?

02

Случај чува број догађаја и скуп њихових типова, без дуплирања.

Питање: која граница мора бити видљива?

03

Правило корелације се тестира познатим низом догађаја и очекиваним случајем.

Питање: који доказ остаје после исхода?

ПИТАЊЕ ЗА АНАЛИЗУ

Који низ догађаја у вашем систему заједно значи више него сваки појединачно?

Контрола

смањује одређени ризик

01

Контрола је везана за конкретан ризик који смањује и за ток на који се примењује.

Питање: који улаз покреће ову одлуку?

02

Ефективност је удео заустављених покушаја у односу на све покушаје.

Питање: која граница мора бити видљива?

03

Контрола која никада није била на проби не сматра се ефективном.

Питање: који доказ остаје после исхода?

ПИТАЊЕ ЗА АНАЛИЗУ

Којим бројем бисте показали да ваша контрола заиста зауставља покушаје?

Доказ и учење

мери и побољшава

01

**Доказ ефективности мора бити
свеж; после промене тока оцена се
поново утврђује.**

Питање: који улаз покреће ову одлуку?

02

**Циљни удео је унапред одређен, па
се резултат пореди са прагом, а не
са утиском.**

Питање: која граница мора бити
видљива?

03

**Резултат мерења води до корекције
контроле или до прихватања
преосталог ризика.**

Питање: који доказ остаје после
исхода?

ПИТАЊЕ ЗА АНАЛИЗУ

Који ризик контрола ублажава, који доказ чува и који сигнал показује да је престала да ради?

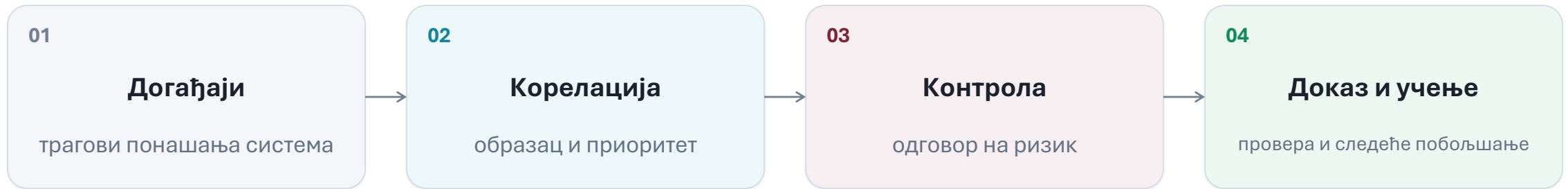
Доказ, покривеност и ефективност

Поређење приказује функцију сваког елемента и ограничење његове самосталне примене.

Питање	Слаб одговор	Поуздан одговор
Да ли контрола постоји?	Класа или подешавање је присутно.	Контрола има власника, активну конфигурацију и сврху.
Да ли ради?	Једном је ручно проверена.	Постоји поновљив тест или актуелан оперативни доказ.
Шта покрива?	Претпоставља се да важи свуда.	Познати су сценарио, граница и изузеци.
Како знамо да је ослабила?	Проблем се види тек после инцидента.	Метрика, alert или редован преглед откривају одступање.

Модел континуираног унапређивања безбедности

Безбедност напредује кроз повратну спрегу. доказ мења разумевање ризика, а то мења контролу.



ЕЛЕМЕНТИ АНАЛИЗЕ

Анализа сваког корака обухвата покретача, место одлуке и траг који остаје после исхода.

Безбедносна повратна спрега

Процес приказује улазе, место одлуке и доказ који остаје после исхода.

КОНТЕКСТ

Безбедносна повратна спрега

Зрео систем не завршава безбедност имплементацијом контроле. Догађаји и тестови стварају доказ, доказ мења процену ризика, а процена ризика води ка бољој политици или другачијој контроли. Тако се избегава лажни осећај да је једном завршени посао заувек довољан.

01

Догађај или тест открива образац који захтева пажњу.

02

Корелација повезује образац са имовином, актером и контролом.

03

Тим проверава да ли постојећа контрола покрива стварни сценарио.

04

Нова одлука ствара ажурирану политику, тест или оперативну процедуру.

Контрола има смисао тек уз доказ

Наведена правила остају видљива у имплементацији, тестовима и ревизији.

01

Корелација повезује догађаје по времену, актеру и ресурсу, уз садржај појединачних порука лога.

Јасно правило

02

Одговор са већим последицама захтева људску одлуку и јасан траг одобрења.

Проверљива примена

03

Постинцидентни преглед испитује системске и процесне узроке догађаја.

Видљив доказ

Примена у развоју

Тим примењује тему кроз серверске провере, тестове и ревизионе записе током развоја.

РАЗВОЈНИ КОНТЕКСТ

Примена принципа у коду

Добра безбедносна анализа показује узрочну везу: коју имовину штитимо, који сценарио разматрамо, која контрола делује и како знамо да њено понашање још увек одговара намери. Кратак, јасан доказ вреди више од дуге листе функционалности.

01

Дефинисана одлука и њена граница.

02

Серверска имплементација провере.

03

Позитиван и негативан доказ.

Случај: контрола постоји, али нема свеж доказ

Случај повезује опште правило са конкретним контекстом, серверском провером и очекиваним исходом.

СЦЕНАРИО

Пример: контрола постоји, али нема свеж доказ

Систем има правило које ограничава приступ осетљивом ресурсу. Правило је било успешно тестирано пре неколико месеци, али се у међувремену променио модел улога и додат је нови улаз у систем. Без новог доказа тим зна да контрола постоји, али не зна да ли још покрива стварни ризик. Ефективност зато укључује свежину, опсег и резултат провере.

01

Корелација повезује низ догађаја у једну причу о понашању система.

02

Мера ефективности прати да ли контрола има власника, доказ и покривеност релевантног сценарија.

03

Аутоматизован одговор може убрзати реакцију, али радња са великом последицом задржава људску потврду и ревизиони траг.

Корелација гради причу, не закључак из једног записа

Корелација групише догађаје по идентификатору тока и бележи њихове типове.

```
1 public IReadOnlyList<CorrelationCase> Correlate(  
2     IEnumerable<SecurityEvent> events)  
3 {  
4     return events  
5         .GroupBy(securityEvent => securityEvent.CorrelationId)  
6         .Select(group => new CorrelationCase(  
7             group.Key,  
8             group.Count(),  
9             group.Select(securityEvent => securityEvent.Type)  
10                .ToHashSet(StringComparer.OrdinalIgnoreCase)))  
11         .ToArray();  
12 }
```

ТУМАЧЕЊЕ

Correlation ID повезује појединачне догађаје у случај са бројем догађаја и скупом типова.

БЕЗБЕДНОСНА ГРАНИЦА

Одбијање је експлицитан исход са разлогом који се може тестирати и објаснити.

Контрола без мерења не важи као ефективна

Тест показује да контрола која никада није била на проби не добија оцелу да ради.

```
1 [Test]
2 public void Evaluate_WhenControlWasNeverExercised_DoesNotClaimItWorks()
3 {
4     var effectiveness = _calculator.Evaluate(
5         new ControlMeasurement("step-up", 0, 0));
6
7     using (Assert.EnterMultipleScope())
8     {
9         Assert.That(effectiveness.Ratio, Is.Zero);
10        Assert.That(effectiveness.MeetsTarget, Is.False);
11    }
12 }
```

ДОКАЗ

Без иједног покушаја удео је нула, а циљ се не сматра испуњеним.

ОЧЕКИВАНИ ИСХОД

Тест не дозвољава да одсуство мерења изгледа као успех контроле.

Садржај безбедносног записа

Запис садржи контекст потребан за реконструкцију одлуке, без тајни и непотребних личних података.

```
1 {  
2   "control": "object-authorization",  
3   "risk": "cross-tenant-access",  
4   "lastEvidence": "2026-09-20",  
5   "coveredScenario": "foreign-record-denied",  
6   "status": "effective",  
7   "nextReview": "2026-10-20"  
8 }
```

ДОВОЉНО

Актер, радња, циљ, исход и разлог

Временска ознака и correlation ID повезују траг са остатком тока.

НЕ ПРИПАДА У ДОКАЗ

Лозинка, token, тајна и сувишан садржај

Траг не сме да постане нови извор цурења или збирка непотребних података.

Честе грешке у имплементацији

Грешке настају када контекст, место одлуке или доказ остану нејасни.

01

**Закључивање из једног
догађаја без ширег контекста.**

Нема јасног власника одлуке.

02

**Аутоматска акција са великом
последicom без заштитне
провере.**

Не постоји негативан сценарио.

03

**Оцена контроле само по томе
да ли је имплементирана.**

Доказ не показује стварни исход.

Процена ефективности контроле

Процена користи актуелан доказ, покривеност релевантних сценарија и позната ограничења.

ОБРАЗЛОЖЕЊЕ

ЕФЕКТИВНОСТ КОНТРОЛЕ

Контрола може бити имплементирана, али погрешно подешена, заобиђена новим током или застарела после промене система. Зато се њена ефективност процењује кроз доказ: последњи успешан тест, покривени сценарио, власника и способност да се проблем примети ако контрола закаже.

01

Доказ се освежава када се промени релевантан ток, улога или граница поверења.

02

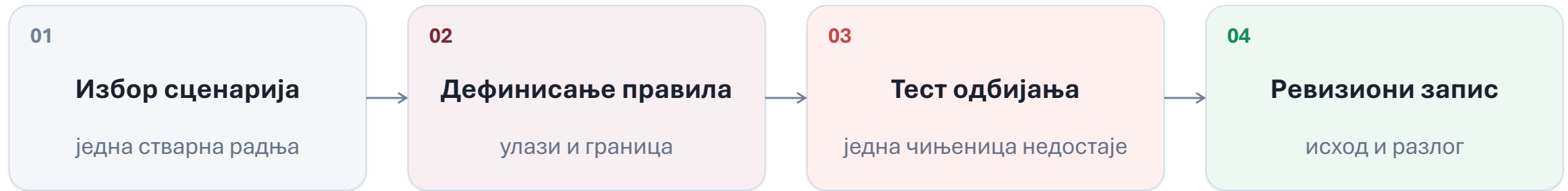
Мера ефективности јасно приказује области за које нема довољно доказа.

03

Квалитетна анализа повезује ризик, контролу, тест и преостало ограничење у једну јасну причу.

Примена на пројекат

Анализа једног сценарија обухвата одлуку, имплементацију, тест одбијања и доказ.

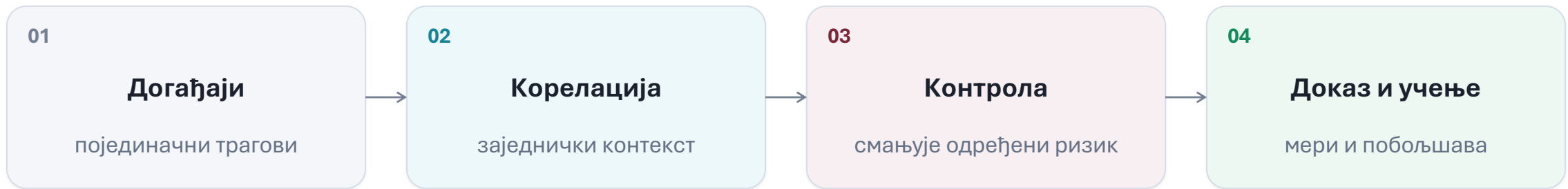


ПРИМЕНА НА ПРОЈЕКАТ

Пројектна примена теме „Корелација догађаја, ефективност контрола и учење“ обухвата једну серверску одлуку, тест одбијања и доказ који други члан тима може да понови.

Провера разумевања

Разумевање теме подразумева објашњење одлуке и доказа независно од конкретног технолошког оквира.



ПИТАЊЕ ЗА ПРОВЕРУ

Који ризик контрола ублажава, који доказ чува и који сигнал показује да је престала да ради?

Пројектна примена: применити исти модел на једну реалну границу у сопственом пројекту.